



Profa. Anelise Munaretto

Redes sem Fio — Ciência da Computação

2026

Ao final desta aula, você será capaz de:

- **explicar** o ataque KRACK e **comparar** WPA2-PSK com WPA3-SAE;
- **descrever** a evolução WEP → WPA → WPA2 → WPA3 (criptografia e autenticação);
- **analisar** a segurança de LoRaWAN (OTAA vs. ABP) e do 5G AKA (SUCI, home control);
- **estimar** o tempo de ataque por força bruta a um PSK;
- **identificar** ameaças (*evil twin*, dicionário offline, *deauth*) e as mitigações correspondentes.

Pré-requisitos

Aulas 2 (fundamentos de redes sem fio) e 8 (IoT e redes LPWAN).

Padrão	Criptografia	Autenticação	Ano
WEP	RC4 (64/128 bits)	Chave compartilhada	1999
WPA	TKIP/RC4	PSK / 802.1X	2003
WPA2	AES-CCMP	PSK / 802.1X	2004
WPA3	AES-GCMP-256	SAE (Simult. Auth. of Equals)	2018
WPA3-Enterprise	AES-GCMP-128/256	EAP-TLS, SuiteB	2018

WPA3: principais novidades

- **SAE** (Dragonfly handshake): protege contra ataques de dicionário offline
- **Perfect Forward Secrecy** (PFS)
- **PMF** (Protected Management Frames): obrigatório
- **Wi-Fi Easy Connect** (DPP): onboarding seguro

KRACK (2017)

- Key Reinstallation Attack (Mathy Vanhoef)
- ataque ao 4-way handshake do WPA2
- força reuso de nonce → quebra criptografia
- afeta todos os clientes WPA2
- corrigido em patches (CVE-2017-13077 a 13084)

Evil Twin / Rogue AP

- AP malicioso com mesmo SSID
- captura de credenciais (phishing)
- WPA3-Enterprise mitiga com certificado de servidor

Dicionário offline

- WPA2-PSK: capturar 4-way handshake e tentar senhas
- ferramentas: aircrack-ng, hashcat
- WPA3 SAE torna essa abordagem inviável

Deauth Attack

- envio de quadros de desautenticação falsos
- PMF obrigatório no WPA3 evita

- **LoRaWAN:** criptografia AES-128 (NwkSKey, AppSKey)
 - OTAA (Over-The-Air Activation) vs. ABP (Activation By Personalization)
 - OTAA mais seguro: chaves renovadas a cada join
 - vulnerabilidade: payload pode ser descriptografado se AppSKey é exposta
- **NB-IoT / LTE-M:** segurança herdada do LTE (AES, SIM-based)
 - autenticação mútua UE-rede (AKA)
 - criptografia NAS e AS
 - chaves armazenadas no SIM

Desafio IoT

Dispositivos com recursos limitados (CPU, memória) dificultam atualizações de segurança e rotação de chaves.

5G AKA (Authentication and Key Agreement)

- evolução do EPS-AKA (4G)
- SUPI (identidade permanente) cifrado como SUCI
- *home control*: rede doméstica sempre envolvida
- chaves derivadas: K, CK, IK, K_{AMF} , etc.

Inovações de segurança 5G

- **SEPP**: proteção entre operadoras (signaling)
- **Network Slicing**: isolamento entre slices
- **MEC security**: execução confiável na borda
- **NR encryption**: AES-128/256, Snow3G, ZUC

- **Quantum computing:** ameaça a criptografia atual (RSA, ECC)
- **Supply chain:** backdoors em hardware/chipsets
- **Privacidade:** rastreamento de dispositivos (MAC aleatório, IMSI catcher)
- **Atualizações:** dispositivos IoT sem mecanismo de patch
- **Regulamentação:** Lei Geral de Proteção de Dados (LGPD), ePrivacy

Problema: estimar o tempo para quebrar por força bruta um PSK de 8 caracteres com alfabeto de 62 símbolos (A–Z, a–z, 0–9).

❶ **Espaço de chaves:**

$$62^8 = 218\,340\,105\,584\,896 \approx 2,18 \times 10^{14}.$$

❷ **Tempo a 10^5 tentativas/s:**

$$\frac{2,18 \times 10^{14}}{10^5} = 2,18 \times 10^9 \text{ s} \approx 69,2 \text{ anos}.$$

❸ **Comparação com dicionário:** com 10^8 senhas comuns a 10^5 /s, o ataque leva apenas 10^3 s $\approx$ 17 min — por isso senhas fracas são o ponto fraco do WPA2-PSK.

Por que o WPA3-SAE (Dragonfly) muda o jogo?

No SAE o segredo não é comparável offline: cada tentativa exige um *round-trip* com o AP (sujeito a *rate-limiting*), inviabilizando o ataque de dicionário offline.

- **Wi-Fi:** WEP (RC4) → WPA (TKIP) → WPA2 (AES-CCMP) → WPA3 (AES-GCMP, SAE).
- **WPA3-SAE:** resistente a dicionário offline, PFS e PMF obrigatório.
- **KRACK (2017):** reinstalação de chave no 4-way handshake do WPA2; corrigido por patches (CVE-2017-13077–13084).
- **Ameaças:** *evil twin*/Rogue AP, dicionário offline, *deauth* falso.
- **LoRaWAN:** AES-128 com NwkSKey/AppSKey; OTAA renova chaves a cada *join* (mais seguro que ABP).
- **5G AKA:** SUPI cifrado como SUCI, *home control*, chaves derivadas (K, CK, IK, K_{AMF}); SEPP protege o signaling entre operadoras.
- **Quantitativo:** $62^8 \approx 2,18 \times 10^{14}$; a 10^5 tentativas/s → ≈ 69 anos.

❶ O ataque KRACK explora:

- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
- (b) a ausência de criptografia no WEP
- (c) o roubo da senha no servidor RADIUS

- ❶ O ataque KRACK explora:
- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
 - (b) a ausência de criptografia no WEP
 - (c) o roubo da senha no servidor RADIUS

Gabarito: (a)

- ❷ No WPA3, o PSK é substituído pelo protocolo:
- (a) EAP-TLS
 - (b) SAE (Simultaneous Authentication of Equals)
 - (c) TKIP/RC4

❶ O ataque KRACK explora:

- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
- (b) a ausência de criptografia no WEP
- (c) o roubo da senha no servidor RADIUS

Gabarito: (a)

❷ No WPA3, o PSK é substituído pelo protocolo:

- (a) EAP-TLS
- (b) SAE (Simultaneous Authentication of Equals)
- (c) TKIP/RC4

Gabarito: (b)

❸ Em LoRaWAN, o modo OTAA é mais seguro que o ABP porque:

- (a) usa AES-64 em vez de AES-128
- (b) dispensa o servidor de rede
- (c) renova as chaves de sessão a cada *join*

❶ O ataque KRACK explora:

- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
- (b) a ausência de criptografia no WEP
- (c) o roubo da senha no servidor RADIUS

Gabarito: (a)

❷ No WPA3, o PSK é substituído pelo protocolo:

- (a) EAP-TLS
- (b) SAE (Simultaneous Authentication of Equals)
- (c) TKIP/RC4

Gabarito: (b)

❸ Em LoRaWAN, o modo OTAA é mais seguro que o ABP porque:

- (a) usa AES-64 em vez de AES-128
- (b) dispensa o servidor de rede
- (c) renova as chaves de sessão a cada *join*

Gabarito: (c)

❹ No 5G AKA, a identidade permanente do usuário (SUPI) é transmitida:

- (a) em texto claro no rádio

❶ O ataque KRACK explora:

- (a) a reinstalação da chave de sessão no 4-way handshake do WPA2
- (b) a ausência de criptografia no WEP
- (c) o roubo da senha no servidor RADIUS

Gabarito: (a)

❷ No WPA3, o PSK é substituído pelo protocolo:

- (a) EAP-TLS
- (b) SAE (Simultaneous Authentication of Equals)
- (c) TKIP/RC4

Gabarito: (b)

❸ Em LoRaWAN, o modo OTAA é mais seguro que o ABP porque:

- (a) usa AES-64 em vez de AES-128
- (b) dispensa o servidor de rede
- (c) renova as chaves de sessão a cada *join*

Gabarito: (c)

❹ No 5G AKA, a identidade permanente do usuário (SUPI) é transmitida:

- (a) em texto claro no rádio

Auditoria Wi-Fi controlada e legal

- Montar um AP de laboratório próprio (sem acesso à rede de produção) e capturar o tráfego com Wireshark em modo monitor.
- Demonstrar o **4-way handshake**: identificar as mensagens EAPOL 1–4 na captura.
- Com aircrack-ng/hashcat, testar a PSK em *wordlist* pequena para observar o ataque de dicionário offline ao WPA2-PSK.
- Repetir com WPA3 (se o AP suportar) e verificar que a captura offline não permite o mesmo ataque (SAE).

Ética e legalidade

Executar apenas em equipamentos próprios e com autorização; interferir em redes alheias viola a lei (Lei 12.737/2012 – Lei Carolina Dieckmann).

- IEEE 802.11i-2004 (WPA2); Wi-Fi Alliance, WPA3 Specification v3.0
- M. Vanhoef, F. Piessens, “Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2”, ACM CCS 2017
- 3GPP TS 33.501, *Security architecture and procedures for 5G system*
- LoRa Alliance, *LoRaWAN 1.1 Specification: Security*
- NIST SP 800-38B, *Recommendation for Block Cipher Modes of Operation*

- IEEE 802.11i-2004 (WPA2) e Wi-Fi Alliance, *WPA3 Specification v3.0* — os dois padrões que definem o que vimos em sala.
- M. Vanhoef, F. Piessens, “Key Reinstallation Attacks: Forcing Nonce Reuse in WPA2”, *ACM CCS 2017* — o artigo original do KRACK.
- 3GPP TS 33.501, *Security architecture and procedures for 5G system* — especificação oficial do 5G AKA e do SUPI/SUCI.
- LoRa Alliance, *LoRaWAN 1.1 Specification: Security* — OTAA/ABP e derivação de chaves.
- NIST SP 800-38B — modos de operação de cifras de bloco (contexto do AES-GCM do WPA3).

Dica de estudo

Refaça o cálculo do exercício com senhas de 10 e 12 caracteres para ver como o espaço de chaves cresce exponencialmente.